دفترچهٔ استاد · جلسهٔ ۴ از ۵

امنیت و ارزیابی عامل‌های کدنویسی شهودی

راهنمای دقیقه‌به‌دقیقه، کارگاه‌ها، کژفهمی‌ها و سنجهٔ نمره‌دهی

مدت: ۱۸۰ دقیقه **۵۰ اسلاید** **۳ کارگاه + ۱ تمرین**

فهرست

1. آمادگی پیش از کلاس
2. قوس روایی جلسه
3. راهنمای دقیقه‌به‌دقیقه
4. اجرای کارگاه‌ها
5. کژفهمی‌های رایج
6. پرسش‌های محتمل و پاسخ‌ها
7. مدیریت زمان و نقشهٔ اضطراری
8. سنجهٔ نمره‌دهی

۱. آمادگی پیش از کلاس

قاعدهٔ اخلاقی که باید در دقیقهٔ اول اعلام شود

همهٔ تمرین‌های امنیتی این جلسه فقط روی **محیط و پروژهٔ آزمایشی خود فراگیر** انجام می‌شوند. هیچ تمرینی نباید علیه سامانهٔ تولیدی، سامانهٔ شخص ثالث یا زیرساختی که مجوز کتبی تست (`test`) آن را ندارید اجرا شود. این را شفاف بگویید و از کلاس تأیید بگیرید.

۴۸ ساعت قبل

- از هر فراگیر بخواهید **یک نمونهٔ واقعی کد تولیدشدهٔ عامل** (`agent`) از پروژهٔ خودش بیاورد که هنوز بازبینی امنیتی نشده. این مادهٔ خام کارگاه ۱ است.

- از فراگیران بخواهید ده نشست (session) اخیرشان با عامل را در دسترس داشته باشند (برای تمرین اصلاح‌ها).

۳۰ دقیقه قبل

- یک نمونهٔ کد تولیدشده با **هر دو الگوی خطا** آماده کنید (کلید در سمت مرورگر + جدول بدون کنترل دسترسی سطح ردیف) برای وقتی که فراگیری نمونه نیاورده باشد.
- یک قطعه کد پرمخاطره برای کارگاه ۲ آماده کنید؛ ترجیحاً مهاجرت پایگاه داده با یک عملیات برگشت‌ناپذیر پنهان.
- سه خلاصهٔ مسیر (trajectory) اجرا برای تمرین تشخیص انحراف قصد (Intent Drift) آماده کنید (دو سالم، یکی منحرف).

۲. قوس روایی جلسه

1. **اعتماد صفر و یکی مرده است:** عامل می‌تواند توکن (token) معتبر داشته باشد و قصد (intent) ناهم‌راستا.
2. **پس دو محور لازم داریم:** امنیت (ماند درون مرز؟) و ارزیابی (evaluation) (آنچه درون مرز شد ارزش داشت؟).
3. **امنیت یعنی مهار** (harness) **بیرونی:** هفت ستون، سندباکس، هویت (identity) عامل‌محور، سه‌گانهٔ عملیات، رصدپذیری (observability).
4. **اما امنیت فقط ثابت می‌کند آسیبی نزد.**
5. **ارزیابی یعنی باز کردن جعبهٔ شیشه‌ای:** هفت بُعد، هفت روش، و سنجش هم‌گرایی نشست (Session convergence) به‌جای درستی تک‌نوبتی.

> **جملهٔ گشایش و جملهٔ پایان**
>
> گشایش: «سه جلسه عامل را توانمندتر کردیم. امروز می‌پرسیم چه چیزی ممکن است خراب شود — و مهم‌تر، از کجا می‌فهمیم.»
>
> پایان: «تولید تا حد زیادی حل شده است. راستی‌آزمایی، امنیت و قضاوت معماری، پیشهٔ تازه‌اند.»

۳. راهنمای دقیقه‌به‌دقیقه

۰۰:۰۰ – ۰۰:۱۵ — گشایش اسلاید ۱–۵

بگویید (اسلاید ۳ – مهم‌ترین تمایز جلسه): «امنیت به شما می‌گوید عامل درون مرز ماند. ارزیابی به شما می‌گوید آنچه درون آن مرز اتفاق افتاد ارزش انتشار داشت. و این دو کاملاً مستقل‌اند: عاملی می‌تواند همهٔ وارسی‌های امنیتی را پاس کند و همچنان چیزی بسازد که اصلاً آن چیزی نیست که خواستید.»

بپرسید (اسلاید ۴): «در نرم‌افزار عادی، از کجا می‌فهمید یک سرویس قابل‌اعتماد است؟» پاسخ‌ها معمولاً: تست‌ها پاس می‌شوند، توکن معتبر است، گزارش‌ها تمیزند.
بعد بگویید: «حالا فرض کنید سامانه‌ای دارید که **همهٔ این‌ها را دارد** و در عین حال دارد کاری می‌کند که شما نخواسته‌اید. این وضعیت در نرم‌افزار قطعی (deterministic) معنا ندارد، اما در سامانهٔ عامل‌محور عادی است.»

۰۰:۱۵ – ۰۰:۴۰ — هفت ستون اسلاید ۶–۱۱

این بخش را به فهرست‌خوانی تبدیل نکنید

هفت ستون، هفت اسلاید متوالی است و خطر خستگی بالاست. راه‌حل: در هر ستون فقط **یک پرسش** از کلاس بپرسید: «این ستون در سازمان شما مالک دارد؟» و بروید جلو. در پایان، اسلاید ۱۱ (جدول جمع‌بندی) را باز بگذارید و بگذارید فراگیران خلأهای مالکیت را ببینند.

بگویید (اسلاید ۵): «گذار اصلی این است: از **هویت به‌مثابه محیط** به **زمینه به‌مثابه محیط** (Context-as-a-Perimeter). در مدل قدیم، اگر توکن درست بود، سامانه به مسیر اجرا اعتماد می‌کرد. در مدل تازه، خودِ توکن هیچ چیزی را اثبات نمی‌کند؛ باید بپرسیم این درخواست در این لحظه با قصد اولیه هم‌راستاست یا نه.»

۰۰:۴۰ – ۰۱:۰۵ — سندباکس و زنجیرهٔ تأمین اسلاید ۱۲–۱۷

این بخش ملموس‌ترین و به‌یادماندنی‌ترین قسمت جلسه است. وقت بگذارید.

بپرسید (پیش از اسلاید ۱۴): «چند نفرتان تا حالا بسته‌ای را نصب کرده‌اید که عامل پیشنهاد داده؟ چند نفر پیش از نصب، بررسی کردید که آن بسته واقعاً وجود دارد و همانی است که فکر می‌کنید؟»
فاصلهٔ میان این دو عدد، کل استدلال بخش بسته‌های توهمی را می‌سازد.

بگویید (اسلاید ۱۴): «این حمله چیز تازه‌ای است و ویژهٔ عصر عامل. مهاجم لازم نیست به شما نفوذ کند؛ کافی است حدس بزند مدل چه نام ساختگی‌ای تولید می‌کند و همان نام را با بدافزار منتشر کند. و چون عامل می‌تواند گراف وابستگی (dependency) را بدون تأیید شما عوض کند، یک توهم (hallucination) کافی است.»

اسلاید ۱۵ را حتماً بگویید

«فهرست دامنه‌های مجاز کافی نیست» یک نکتهٔ ظریف اما حیاتی است که بیشتر تیم‌ها اشتباه می‌کنند: فهرست مجاز نمی‌تواند شما را در برابر تزریق پرامپتی که **درون** یک صفحهٔ مجاز پنهان است محافظت کند. پاسخ، دسترسی غیرتعاملی است، نه فهرست بلندتر.

۰۱:۰۵ – ۰۱:۱۵ — استراحت اول

۰۱:۱۵ – ۰۱:۳۵ — منطق برنامه و هویت اسلاید ۱۸–۲۵

بگویید (اسلاید ۱۶): «این دو الگو را حفظ کنید، چون در تقریباً هر برنامه‌ای که سریع با هوش مصنوعی ساخته شده می‌بینیدشان: اعتماد بیش‌ازحد به مرورگر، و پشتیبان رهاشده. و ریشهٔ مشترکشان یک فرض است: **چون کامپایل می‌شود، پس امن است.**»

بپرسید (اسلاید ۱۹): «اگر کسی دستور (instruction) مخربی را در فایل README یک ریپو (repository) متن‌باز پنهان کند و شما آن را در زمینهٔ عاملتان بچسبانید، چه اتفاقی می‌افتد؟»
همین سناریو دقیقاً معاون گیج (Confused Deputy) است و بهتر است پیش از نام‌بردنش، کلاس خودش به آن برسد.

بگویید (اسلاید ۲۱ — نکتهٔ عملی‌ای که فوری قابل استفاده است): «دکمهٔ تأیید، امنیت نیست؛ رسم است. وقتی پنجاه بار در روز تأیید می‌زنید، تأیید پنجاه‌ویکم بی‌معنا می‌شود. تفاوت‌نمای شهودی (Vibe Diff) این را حل می‌کند: پیش از کنش پرمخاطره، کد به زبان ساده ترجمه می‌شود تا واقعاً بدانید چه چیزی را تأیید می‌کنید.»

۰۱:۳۵ – ۰۱:۵۵ — کارگاه ۱ اسلاید ۴۰

توجه: اسلاید کارگاه در انتهای بخش ارزیابی قرار گرفته است تا در فایل اسلاید پیوسته بماند. در کلاس، همین‌جا به آن بروید و بعد به مسیر عادی برگردید. جزئیات در بخش کارگاه‌ها.

۰۱:۵۵ – ۰۲:۲۰ — سه‌گانه و رصدپذیری اسلاید ۲۲–۳۳

بگویید (اسلاید ۲۳): «نویسه‌های با عرض صفر و هم‌ریخت‌ها، حمله‌ای قدیمی‌اند. چیزی که تازه است، **سرعت پخش** است: عامل کد را صدها برابر سریع‌تر از انسان تکثیر می‌کند، پس یک پیلود `(payload)` مخرب پنهان ظرف چند دقیقه در صدها فایل پخش می‌شود.»

اسلاید ۲۶ را برجسته کنید

«قرنطینهٔ باحالت `(Stateful quarantine)`» مفهومی است که بیشتر تیم‌های امنیتی به آن فکر نکرده‌اند: کشتن ظرف، عامل را در میانهٔ تفکر قطع می‌کند و APIهای متصل را خراب رها می‌کند. راه درست، سلب دسترسی ابزار `(tool)` با حفظ حافظهٔ کوتاه‌مدت است. اگر در کلاس فراگیر امنیتی دارید، همین‌جا بحث خوبی درمی‌گیرد.

بپرسید (اسلاید ۲۹): «اگر عامل شما امشب وارد حلقهٔ بی‌پایان شود، صبح چه کسی متوجه می‌شود و چطور؟» معمولاً پاسخ این است: «وقتی صورت‌حساب بیاید.» همین، بهترین مقدمه برای بحث انکار کیف پول `(Denial of Wallet)` است.

تمرین کلاسی: تشخیص انحراف `(drift)` قصد (۸ دقیقه، پس از اسلاید ۳۱)

سه خلاصهٔ مسیر اجرا را بخوانید. کلاس باید بگوید کدام انحراف قصد دارد و **در کدام گام** باید قطع‌کننده فعال می‌شد.

نمونهٔ کلاسیک: «پرس‌وجوی پایگاه داده را بهینه کن» ← عامل جدول را می‌خواند ← برنامهٔ اجرا را بررسی می‌کند ← **می‌کوشد کتابخانهٔ نمایه‌سازی تازه‌ای نصب کند.** گام سوم، نقطهٔ انحراف است.

۰۲:۲۰ – ۰۲:۳۰ — استراحت دوم

۰۲:۳۰ – ۰۲:۵۵ — ارزیابی: چرا و چه اسلاید ۳۴–۳۹

بگویید (اسلاید ۳۶): «"داشبورد را سریع‌تر کن" یک پروندهٔ تست نیست. این جملهٔ ساده، کل مسئلهٔ ارزیابی کدنویسی شهودی (Vibe coding) را خلاصه می‌کند: مشخصاتی وجود ندارد که در برابرش بسنجیم، و نخستین کار ارزیابی این است که بسنجد آیا عامل مشخصات (spec) نانوشتهٔ **درست** را بازسازی کرد یا نه.»

بپرسید (اسلاید ۳۷، بُعد ۲): «چطور می‌شود بُعد درستی کارکردی را تقلب کرد؟» پاسخ هدف: حذف یا جعل تست‌ها. سپس بپرسید: «چطور جلویش را می‌گیرید؟» و به حلقهٔ تست‌محورِ اسلاید ۲۷ برگردید — جایی که عامل نمی‌تواند هم‌زمان تست و پیاده‌سازی را تغییر دهد.

اسلاید ۳۹ کوچک اما مهم است

«ابعاد مستقل نیستند» یک ابزار تشخیص عملی است: اگر رضایت قصد پایین است، پیش از دست‌کاری پرامپت‌ها **مسیر** را بررسی کنید. اغلب ریشه همان‌جاست.

۰۲:۵۵ – ۰۳:۱۰ — چگونه بسنجیم اسلاید ۴۱–۴۴

جدول‌های ۴۱ و ۴۲ را سطربه‌سطر نخوانید. به‌جایش یک بُعد را انتخاب کنید (پیشنهاد: بُعد ۳، درستی بصری) و نشان دهید چرا فقط یک روش برایش کار می‌کند. بقیه را به جزوه بسپارید.

بگویید (اسلاید ۴۳): «بنچمارک‌ها (benchmark) لازم‌اند، اما مراقب باشید: امتیاز بالا در بنچمارکی که روی ریپوهای ساختارمند کار می‌کند، هیچ چیزی دربارهٔ توانایی عامل در ساخت یک برنامهٔ مصرفی نمی‌گوید. بنچمارک برای **کالیبراسیون شناختی** است، نه جایگزین ارزیابی قصد.»

۰۳:۱۰ – ۰۳:۲۰ — نکته‌های کاربردی و جمع‌بندی اسلاید ۴۵–۵۰

اگر فقط یک نکتهٔ کاربردی وقت دارید، این را بگویید

اسلاید ۴۸ — اصلاح‌های کاربر دادهٔ برچسب‌خوردهٔ رایگان‌اند. هر تیمی همین امروز می‌تواند اجرایش کند و نتیجه‌اش فوری است: خوشه‌بندی «نه، این‌طور نه»ها، سریع‌ترین راه برای دیدن شکاف‌های نظام‌مند عامل است.

۴. اجرای کارگاه‌ها

کارگاه ۱ — بازبینی امنیتی خروجی عامل (۲۰ دقیقه)

1. **دقیقهٔ ۰–۴:** روی نمونهٔ خودتان، سیاههٔ چهارگانه را زنده اجرا کنید تا الگو را ببینند.
2. **دقیقهٔ ۴–۱۵:** کار گروه دونفره روی کد واقعی خودشان.
3. **دقیقهٔ ۱۵–۲۰:** دو گروه یافته‌هایشان را می‌گویند.

معیار سخت‌گیرانه را رها نکنید

یافته باید **فایل، خط و اصلاح مشخص** داشته باشد. اگر گروهی گفت «شاید بهتر باشد امن‌تر بنویسیم»، بپرسید: «کدام خط؟ و اگر بخواهم امروز درستش کنم، دقیقاً چه چیزی را عوض کنم؟»

این سخت‌گیری، تفاوت میان یک کارگاه امنیتی مفید و یک گفت‌وگوی کلی دربارهٔ امنیت است.

کارگاه ۲ — نوشتن تفاوت‌نمای شهودی (۱۵ دقیقه)

قطعه کد پرمخاطره را پخش کنید. هر نفر در حداکثر پنج جملهٔ ساده می‌نویسد که این کد دقیقاً چه می‌کند و چه چیزی برگشت‌ناپذیر است. سپس سه متن را بلند بخوانید.

نقطهٔ آموزشی: هرجا دو نفر برداشت متفاوتی داشته باشند، نقطه‌ای است که تأیید انسانی بدون تفاوت‌نما خطرناک بوده است. این را صریح بگویید — تأثیرش بسیار بیشتر از توضیح نظری است.

کارگاه ۳ — طراحی مجموعهٔ ارزیابی (۱۵ دقیقه، اگر وقت بود)

گروه‌های سه‌نفره، چهار بُعد را پوشش می‌دهند: رضایت قصد، درستی کارکردی، کیفیت مسیر، رفتار خودترمیمی. هنگام بازخورد، روی یک پرسش تمرکز کنید: **«چطور می‌شود این سنجه** `(rubric)` **را تقلب کرد؟»** هر سنجه‌ای که پاسخ روشنی نداشته باشد، هنوز آماده نیست.

۵. کژفهمی‌های رایج

کژفهمی	تصحیح پیشنهادی
«کد کامپایل و اجرا می‌شود، پس امن است.»	کامپایل‌شدن هیچ چیزی دربارهٔ امنیت نمی‌گوید. دقیقاً همین فرض است که کاربران را نسبت به دورزدن کامل کنترل‌های پشتیبان کور می‌کند.
«اگر توکن معتبر باشد، دسترسی مجاز است.»	عامل می‌تواند توکن معتبر داشته باشد و در عین حال با قصد ناهم‌راستا عمل کند. مجوز باید بر پایهٔ زمینه (context) باشد: قصد × کاربر × زمان.
«سندباکس (sandbox) یعنی امنیت کامل.»	سندباکس شعاع اثر را مهار می‌کند، اما مانع نوشتن کد بنیاداً معیوب یا وصل‌شدن به ابزار داخلی مخرب نمی‌شود. به همین دلیل ستون برنامه و ستون هویت هم لازم‌اند.
«فهرست دامنه‌های مجاز، خروج شبکه را امن می‌کند.»	فهرست مجاز نمی‌تواند در برابر تزریق غیرمستقیم پرامپت که درون صفحه‌ای مجاز پنهان است محافظت کند. پاسخ، دسترسی غیرتعاملی است.
«در ویرایشگر جلویش را می‌گیریم.»	مسدودسازی در ویرایشگر به‌آسانی دور زده می‌شود و اصطکاک می‌سازد. ویرایشگر جای راهنمایی است؛ دروازهٔ واقعی در خط لوله است.
«عامل امن، عامل خوب است.»	امنیت فقط ثابت می‌کند آسیبی نزد. اینکه آیا قصد کاربر را برآورده کرده، پرسش کاملاً جداگانه‌ای است که فقط ارزیابی پاسخ می‌دهد.
«اگر تست‌ها سبزند، ارزیابی تمام است.»	درستی کارکردی کف است نه سقف، و آسان‌ترین بُعد برای تقلب. رضایت قصد، کیفیت مسیر و درستی بصری هیچ‌کدام از تست واحد درنمی‌آیند.
«امتیاز بالا در بنچمارک یعنی آمادهٔ تولید.»	بیش‌برازش بنچمارک واقعی است. بنچمارک‌ها قابلیت شناختی را کالیبره می‌کنند؛ دربارهٔ قصد سفارشی و قضاوت زیبایی‌شناختی چیزی نمی‌گویند.

۶. پرسش‌های محتمل و پاسخ‌ها

«همهٔ هفت ستون را که نمی‌توانیم یک‌باره پیاده کنیم. از کجا شروع کنیم؟»

از ستون‌هایی که کمترین هزینه و بیشترین بازده را دارند: سندباکس اجرا (ستون ۱)، قفل نسخه و منبع معتبر برای وابستگی‌ها (ستون‌های ۱ و ۴)، و هویت عامل‌محور به‌جای اعتبارنامهٔ تفویضی (ستون ۵). سپس اولویت‌بندی مخاطره کنید: کدام گردش‌کار (workflow) خودگردان (autonomous) بیشترین اثر کسب‌وکاری را در صورت به‌خطرافتادن دارد؟ همان را اول امن کنید.

«تیم ما تیم امنیت اختصاصی ندارد. سه‌گانهٔ قرمز/آبی/سبز شدنی است؟»

نسخهٔ سبک‌ش شدنی است: تیم قرمز می‌تواند مجموعه‌ای از پرامپت‌های خصمانهٔ ذخیره‌شده باشد که در سی‌آی (CI) اجرا می‌شود؛ تیم آبی می‌تواند چند هشدار ساده روی مصرف توکن و تعداد فراخوان ابزار (tool call) باشد؛ تیم سبز می‌تواند صرفاً نقطهٔ بازگشت خودکار پیش از هر تغییر باشد. کامل نیست، اما از هیچ بسیار بهتر است.

«تفاوت‌نمای شهودی سرعت کار را کم نمی‌کند؟»

بله و عمداً. اما فقط برای کنش‌های **پرمخاطره**. نکته این است که مرز پرمخاطره را صریح تعریف کنید: تغییر پایگاه دادهٔ تولید، انتقال مالی، تغییر پیکربندی دسترسی. برای باقی کارها، اصطکاک اضافه نکنید.

«چطور ارزیابی رضایت قصد را خودکار کنیم وقتی قصد نانوشته است؟»

با تکنیک پیشوند نشست: معیارهای پذیرش را خودکار از یکی دو پیام نخست کاربر استخراج کنید و هر نوبت بعدی را در برابر همان‌ها نمره بدهید. کامل نیست، اما تنها راه عملی در مقیاس است — و بازبینی انسانی نمونه‌ای، همان را کالیبره می‌کند.

«هزینهٔ رصدپذیری کامل خیلی زیاد است.»

به همین دلیل نمونه‌گیری دم‌محور وجود دارد: جمع‌کننده کل رد را پس از پایان ارزیابی می‌کند و موفقیت‌های روزمره را دور می‌ریزد و ردهای دارای خطا یا حلقهٔ خودترمیمی افراطی را نگه می‌دارد. و یادآوری کنید که رصدپذیری اینجا فقط عملیاتی نیست؛ الزام امنیتی است.

«اگر عامل ما فقط کد پیشنهاد می‌دهد و انسان همیشه تأیید می‌کند، باز هم این‌همه لازم است؟»

پرسش خوبی است و پاسخ صادقانه: بخشی‌اش نه. اما دو نکته را یادآوری کنید: خستگی تأیید (Approval fatigue) واقعی است، و وابستگی‌های توهمی حتی با تأیید انسانی هم رد می‌شوند، چون کسی نام بسته‌ها را وارسی نمی‌کند. پس دست‌کم قفل نسخه، منبع معتبر و پویش وابستگی را لازم دارید.

۷. مدیریت زمان و نقشهٔ اضطراری

وضعیت	کاری که بکنید
۱۵ دقیقه عقبید	اسلایدهای ۷ تا ۱۰ (جزئیات ستون‌ها) را به جدول جمع‌بندی اسلاید ۱۱ فشرده کنید و مستقیم به بخش سندباکس بروید.
۳۰ دقیقه عقبید	کارگاه ۳ را حذف کنید و بخش «چگونه بسنجیم» را به دو اسلاید کاهش دهید (۴۱ و ۴۳). اما کارگاه ۱ و ۲ را نگه دارید.
جلو هستید	تمرین انحراف قصد را گسترش دهید و از فراگیران بخواهید مسیرهای واقعی خودشان را بیاورند و تحلیل کنند.
کلاس امنیتی‌تر است	روی اسلایدهای ۱۹ (معاون گیج)، ۲۰ (اختیار محیطی صفر (Zero Ambient Authority)) و ۲۶ (قرنطینهٔ باحالت) عمیق شوید و بخش ارزیابی را سبک‌تر بگیرید.
کلاس توسعه‌محورتر است	روی بخش ارزیابی و چهار نکتهٔ کاربردی (۴۵–۴۸) وقت بگذارید و هفت ستون را فقط با جدول اسلاید ۱۱ بگذرانید.

بخش‌هایی که هرگز حذف نمی‌شوند

دو محور اعتماد (۳)، **بسته‌های توهمی** (۱۴)، **دو الگوی خطا کد** (۱۶)، **اختیار محیطی صفر و** `(authority)` **تفاوت‌نما** (۲۰–۲۱)، و **هفت بُعد ارزیابی** (۳۷–۳۸).

۸. سنجهٔ نمره‌دهی

گزارش بازبینی امنیتی — ۳۰ نمره

معیار	نمره	شاخص کیفیت
یافته‌های مشخص	۱۵	هر یافته با فایل، خط و شرح دقیق آسیب‌پذیری. یافته‌های کلی نمره نمی‌گیرند.
دسته‌بندی بر پایهٔ ستون‌ها	۷	هر یافته به ستون مربوطه نسبت داده شده است.
اصلاح عملی	۸	برای هر یافته، اصلاحی که امروز قابل اجراست — نه توصیهٔ کلی.

طرح مهار مخاطره — ۲۵ نمره

- **۷ نمره:** انتخاب و توجیه پرمخاطره‌ترین گردش‌کار (بر پایهٔ اثر کسب‌وکاری، نه سلیقه).
- **۶ نمره:** طراحی سندباکس و دامنهٔ دسترسی فایل‌سیستم.
- **۶ نمره:** هویت و مجوزها: چه توکنی، با چه دامنه‌ای، با چه عمری.
- **۶ نمره:** نقاط تأیید انسانی و سازوکار بازگشت: دقیقاً کجا انسان مداخله می‌کند و چطور برمی‌گردیم.

مجموعهٔ ارزیابی — ۳۰ نمره

پوشش `(coverage)` دست‌کم چهار بُعد با روش متناسب. نمرهٔ کامل نیازمند این است که برای هر بُعد توضیح داده شود **چرا این روش برای این بُعد درست است** و **چطور می‌شود این سنجه را تقلب کرد.** مجموعه‌ای که فقط تست واحد داشته باشد، حداکثر یک‌سوم نمره را می‌گیرد.

تحلیل اصلاح‌های کاربر — ۱۵ نمره

دست‌کم ده مورد اصلاح واقعی از نشست‌های خود فراگیر، خوشه‌بندی معنادار، و نام‌گذاری سه حالت شکست نظام‌مند. نمرهٔ کامل زمانی است که فراگیر برای دست‌کم یک حالت شکست، اصلاح مشخصی در مهار یا مهارت‌ها `(skill)` پیشنهاد دهد.
